AUDIT REPORT · AUD-2026-IAM-01

Strong authentication and privileged access — KRL-ADM

Banque Ardoise (fictive) · CRM des conseillers

Lead auditor: **A. Auditeur** Owner: **DSI — équipe IAM** Date: **2026-11-02 23:19**

Run: **02-ardoise-crm-conforme**

1. Executive summary

OPINION AT TESTING

Satisfactory

7 controls tested	**0** findings	**0** findings closed and verified	**0** open findings
0 human approvals	**34** personal data items masked in evidence	**0 min 22 s** audit duration	**$0.251 *** measured AI cost

Key messages

- No findings: every tested control is compliant.

2. Scope and method

Engagement	AUD-2026-IAM-01
Entity	Banque Ardoise (fictive)
System	CRM des conseillers
System criticality	Supporte des fonctions critiques ou importantes (DORA)
Environment	Pré-production de démonstration
Owner	DSI — équipe IAM
Lead auditor	A. Auditeur
Date	2026-11-02 23:19
Framework	DORA art. 9(4) · RTS (UE) 2024/1774 art. 12, 21 · PSI-4
Work programme	existing catalogue reused · controls/AUD-2026-IAM-01.en.json

In scope

- Paramètres d'authentification et de session de la console KRL-ADM
- Comptes disposant d'un accès à la console

Out of scope

- Efficacité intrinsèque des facteurs MFA (robustesse des moyens d'authentification)
- Annuaire central et fédération d'identité

- Journalisation des actions d'administration
- Contrôles physiques

Method

1. Controls are derived from the framework (DORA, RTS 2024/1774, internal policy); severity is the one set by the policy.
2. Each test is a stored Python script, statically checked before execution (read-only) and run with a read-only service account.
3. The verdict comes from the script, never from the model. A screenshot is reviewed by Muse Spark to corroborate; on disagreement the control is flagged for review.
4. SAM 3.1 delineates the proving rows and the personal data, which is masked before distribution.
5. Every fix goes through a change request approved by the system owner, applied with a dedicated account, logged, then verified by the same test (DORA 9(4)(e)).
6. Every event and piece of evidence is sealed in a hash-chained audit trail (SHA-256).

Limitations

- Tests cover the configuration reported by the system, not the actual strength of authentication factors.
- AI-drafted scripts and catalogue must be reviewed by an auditor before being considered validated.
- Fictitious entity and data: demonstration.

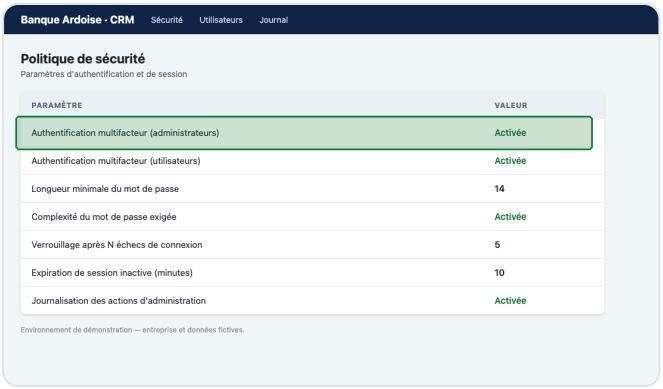
3. Findings overview

REF.	RULE	TITLE	SEVERITY	TESTED	AFTER	STATUS	DUE DATE
—	PSI-4.1	Mandatory MFA for privileged accounts	Critical	Compliant			
—	PSI-4.2	Mandatory MFA for users of critical system	High	Compliant			
—	PSI-4.3	Strong password policy	Medium	Compliant			
—	PSI-4.4	Account lockout after failed logins	Medium	Compliant			
—	PSI-4.5	Inactive session timeout	Medium	Compliant			
—	PSI-4.6	Logging of administration actions	High	Compliant			
—	PSI-4.7	No generic or shared admin accounts	High	Compliant			

4. Detailed findings and controls

PSI-4.1 Mandatory MFA for privileged accounts — Critical — Compliant

Compliant control — MFA is enforced for all privileged admin accounts on KRL-ADM · DORA 9(4)(d), RTS 21(1)(f)(ii)
Observed: `true`

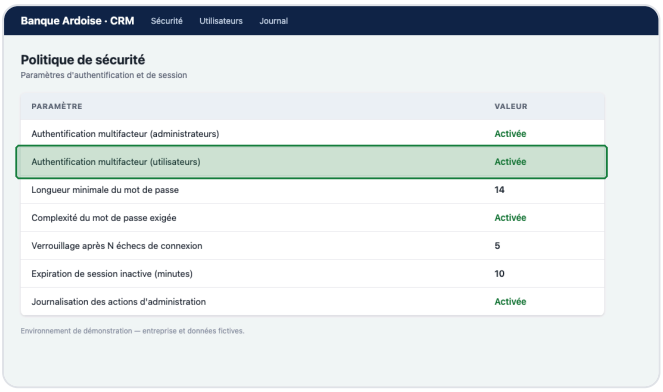


At testing — The screenshot corroborates the test. The first row shows administrator MFA as Activée, matching the reported mfa_admin true.
`2026-11-02 23:19:37 · SHA-256 29ea251eab0b7c90…`

PSI-4.2 Mandatory MFA for users of critical system

High · Compliant

Compliant control — MFA is enforced for standard users because KRL-ADM supports critical or important functions · DORA 9(4)(d), RTS 21(1)(f)(ii)
Observed: `true`

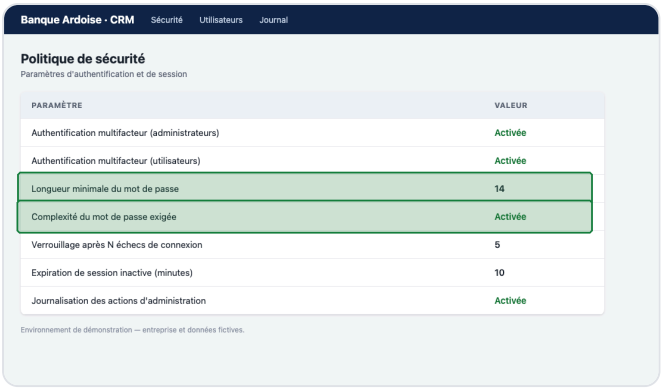


At testing — The screenshot corroborates the test. The screenshot shows MFA for users as Activée, confirming mfa_users is true.
`2026-11-02 23:19:35 · SHA-256 cea849abecf4086b…`

PSI-4.3 Strong password policy

Medium · Compliant

Compliant control — Passwords require a minimum length of 12 characters with complexity requirements enabled · DORA 9(4)(d)
Observed: `{"password_min_length": 14, "password_require_complexity": true}`



At testing — The screenshot corroborates the test. The screenshot shows minimum length 14 and required complexity enabled, matching the automated pass.

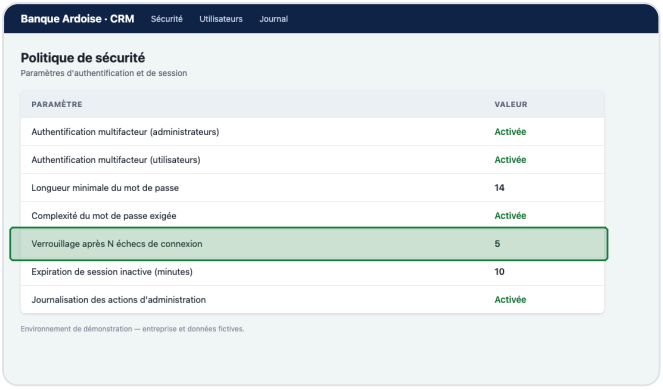
`2026-11-02 23:19:36 · SHA-256 14351bd2ace77c00…`

PSI-4.4 Account lockout after failed logins

Medium · Compliant

Compliant control — Accounts lock after at most 5 failed login attempts and lockout is never disabled · DORA 9(4)(c)

Observed: `5`



At testing — The screenshot corroborates the test. The security policy table shows lockout after 5 failed logins, matching the automated result of 5.

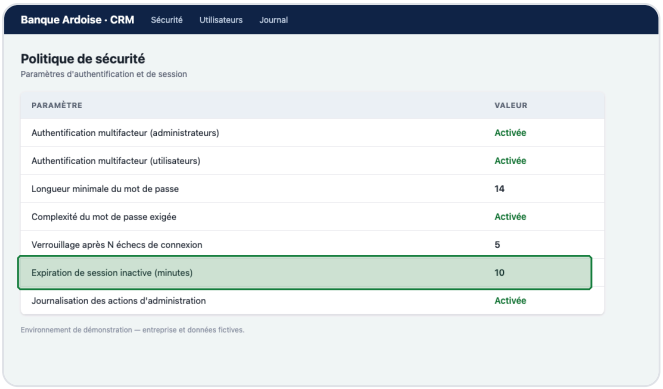
`2026-11-02 23:19:38 · SHA-256 84e3a64b088f7130…`

PSI-4.5 Inactive session timeout

Medium · Compliant

Compliant control — Inactive sessions expire after at most 15 minutes and expiration is never disabled · DORA 9(4)(c)

Observed: `10`

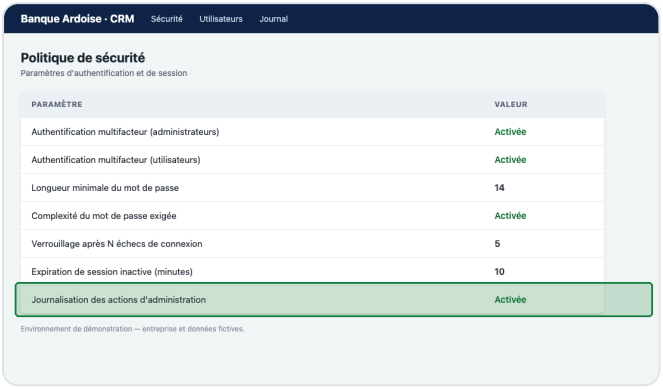


At testing — The screenshot corroborates the test. The screenshot shows inactive session expiration set to 10 minutes, within the required 1 to 15 range.
`2026-11-02 23:19:35 · SHA-256 8e881dc1f4a7dc2f…`

PSI-4.6 Logging of administration actions

High Compliant

Compliant control — All administration actions are logged · RTS 12(2)(c)(i)
Observed: `true`

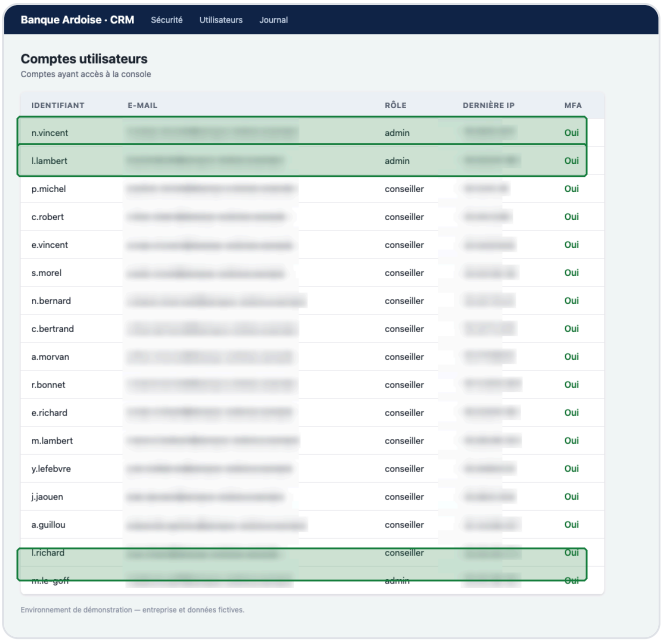


At testing — The screenshot corroborates the test. The screenshot shows Journalisation des actions d'administration as Activée.
`2026-11-02 23:19:37 · SHA-256 b94ae7bd52f3ce81…`

PSI-4.7 No generic or shared admin accounts

High Compliant

Compliant control — No account with role admin is generic or shared and every admin has a nominative login of the form initiale.nom with a personal email · DORA 9(4)(c), RTS 21(1)(c), RTS 21(3)
Observed: `[{"login": "n.vincent", "email": "n•••@banque-ardoise.example", "role": "admin"}, {"login": "l.lambert", "email": "l•••@banque-ardoise.example", "role": "admin"…`



At testing — The screenshot corroborates the test. Screenshot shows exactly three admin rows with initiale.nom logins and personal emails matching the automated test result. · 34/34 personal data items masked (18 spotted by the AI, the rest by the deterministic safety net)

`2026-11-02 23:19:50 · SHA-256 7a6780328b14961a…`

Appendices

A. Traceability matrix

REQUIREMENT	RULE	CONTROL	SCRIPT (SHA-256)	RESULT
DORA 9(4)(d), RTS 21(1)(f)(ii)	PSI–4.1	C1 · Mandatory MFA for privileged accounts	098d37cd0158dd1a · script library (reused)	Compliant
DORA 9(4)(d), RTS 21(1)(f)(ii)	PSI–4.2	C2 · Mandatory MFA for users of critical system	fa35c17fbb1dfdd3 · script library (reused)	Compliant
DORA 9(4)(d)	PSI–4.3	C3 · Strong password policy	b440a5b4dc6b0fb3 · script library (reused)	Compliant
DORA 9(4)(c)	PSI–4.4	C4 · Account lockout after failed logins	10d2a8f06337b5bc · script library (reused)	Compliant
DORA 9(4)(c)	PSI–4.5	C5 · Inactive session timeout	4157e9750f010f98 · script library (reused)	Compliant
RTS 12(2)(c)(i)	PSI–4.6	C6 · Logging of administration actions	e2f3534909210977 · script library (reused)	Compliant
DORA 9(4)(c), RTS 21(1)(c), RTS 21(3)	PSI–4.7	C7 · No generic or shared admin accounts	5e917770866b8e47 · script library (reused)	Compliant

B. Evidence register

FILE			SHA-256
evidence/C1_before.png	C1 · At testing	2026-11-02 23:19:37	29ea251eab0b7c9037b2460ecfc91ed1f3b9a25b5f5178e2ee2d2a57e03926f8
evidence/C2_before.png	C2 · At testing	2026-11-02 23:19:35	cea849abecf4086b7c74bd571f85871c0f91b2b6000e763ac7b40f6256c49eb4
evidence/C3_before.png	C3 · At testing	2026-11-02 23:19:36	14351bd2ace77c00ea64e97f635cd65a0730a3850e01cdb0fc3e60d62c5bb8c8
evidence/C4_before.png	C4 · At testing	2026-11-02 23:19:38	84e3a64b088f713069db54a105cc559a1a5e6101f28bc910e17fe17f6baaea9f
evidence/C5_before.png	C5 · At testing	2026-11-02 23:19:35	8e881dc1f4a7dc2f92820d289b751fb50e14dfc0fa2b64fe799a6a3deee7f71f
evidence/C6_before.png	C6 · At testing	2026-11-02 23:19:37	b94ae7bd52f3ce81b1ac03b74e0050618b722f9dd25e8a9f06d34aa00fce75a8
evidence/C7_before.png	C7 · At testing	2026-11-02 23:19:50	7a6780328b14961a50c244fd841b33fdc38130c32912c89cc501dc7b1dc04896

C. AI usage, costs and human oversight

MODEL	CALLS	INPUT TOKENS	OUTPUT TOKENS	IMAGES	COST (USD)

`muse-spark-1.3`	22	28,164	50,775	0	0.2510
`sam-3.1`	13	0	0	13	price not published
Total					**0.2510**

Personal data in evidence: 18/34 spotted by Muse Spark + SAM, 34/34 masked in the end thanks to the deterministic safety net (page text).

* sam-3.1: price not published (pricing.toml)

Safeguards

- Scripts: allow-listed imports, no write requests (static analysis before execution).
- Read-only test account: any write would be refused by the system (defence in depth).
- Fixes: allow-listed route and parameters, human approval, separate change account.
- Segregation of duties: the approver cannot be the auditor.

D. Integrity

Audit-trail fingerprint when the report was issued. Verify with `python -m attest verify <folder>`.

`e8b82f7a9ad1c3919312c629c6c8d54eb64d4c693416fc71876444b211b73321`